Система учёта и регистрации обучающихся

ASP.NET Core 8 (Razor Pages) + EF Core + PostgreSQL.

Что нужно установить

- .NET 8 SDK
- PostgreSQL 14+ (создавать базу вручную не нужно, достаточно запущенного сервера)
- Инструмент миграций (один раз): `dotnet tool install --global dotnet-ef`

Первый запуск

1. Откройте `TrainingRegistry/appsettings.json` и поправьте строку подключения `ConnectionStrings:Default` (логин, пароль, порт PostgreSQL).
2. В папке `TrainingRegistry` выполните команды:

```
dotnet restore
dotnet ef migrations add Initial
dotnet run
```

При старте приложение само применяет миграции и создаёт двух пользователей.

1. Откройте адрес из консоли (обычно `https://localhost:7xxx`) и войдите:

Логин	Пароль	Роль
`admin`	`Admin123!`	Администратор
`metodist`	`Metod123!`	Методист

В `appsettings.json` строка подключения выглядит так (пароль подставьте свой, в репозиторий его не выкладывайте):

```
Host=localhost;Port=5432;Database=training_registry;Username=postgres;Password=ВАШ_ПАРОЛЬ
```

Пароли можно поменять в `appsettings.json` (раздел `Seed`) до первого запуска. Если миграцию ещё не создавали, приложение создаст схему через `EnsureCreated`, но для работы с миграциями лучше выполнить `dotnet ef migrations add Initial`.

Структура проекта

Папка	Что внутри
`Domain`	Сущности (организации, сотрудники, программы, группы и т. д.), перечисления, правила образования
`Data`	`AppDbContext` (аудит и логическое удаление при сохранении), `DbInitializer` (миграции и начальные пользователи)
`Security`	Роли, политики доступа, текущий пользователь

Папка	Что внутри
`Infrastructure`	Общие средства для списков: пагинация, сортировка, базовая страница `ListPageModel`
`Pages`	Страницы Razor Pages. `Account` — вход и выход

Как работает аудит и удаление

- Все основные сущности наследуют `AuditableEntity`. При сохранении `AppDbContext` сам заполняет «кто и когда создал / изменил» и пишет запись в таблицу `AuditLogs`.
- `Remove(...)` не удаляет строку, а ставит `IsDeleted = true`. Удалённые записи скрыты глобальным фильтром.
- Сохранять нужно только через `SaveChangesAsync`.

Права

- Администратор — доступ ко всему, включая раздел `/Admin`.
- Методист — доступ к обычным разделам. Изменять организации и сотрудников ему можно, только если администратор включил флаги `CanEditOrganizations` и `CanEditPeople` (в начальных данных включены).
- Защита страниц стоит на сервере (`Program.cs`, политики), меню лишь скрывает пункты.

Договоры

- В карточке группы у каждого заказчика (организации или физического лица) есть кнопка «Сформировать договор». В договор попадают все обучающиеся этого заказчика в группе, кроме отчисленных.
- Номер вида `Д-2026-0001` выдаётся по порядку в пределах года. Уникальность гарантирует индекс в БД; номера удалённых договоров повторно не используются.
- Договор создаётся сразу в двух форматах: Word (`.docx`, собирается без сторонних библиотек) и PDF (библиотека QuestPDF, лицензия Community). Файлы лежат в `App_Data/uploads/contracts`, в базе хранится только путь.
- Реквизиты исполнителя (учебного центра) можно задать в `appsettings.json` необязательным разделом:

```
"Contract": {
  "City": "Санкт-Петербург",
  "ExecutorName": "Учебный центр «Пример»",
  "ExecutorInn": "7800000000",
  "ExecutorAddress": "г. Санкт-Петербург, ул. Примерная, д. 1",
  "ExecutorPhone": "+7 (812) 000-00-00",
  "ExecutorSignerPosition": "директора",
  "ExecutorSignerName": "Иванов И. И.",
  "ExecutorBasis": "Устава"
}
```

Если раздел не задан, подставляются значения по умолчанию, а подписи остаются пустыми линиями. Если в группе изменился состав, на странице договора появляется кнопка «Обновить документы».

Выгрузка в Excel

На страницах «Организации», «Сотрудники», «Программы», «Группы» и «Уведомления» есть кнопка «Выгрузить в Excel». В файл попадают все строки, найденные по текущему поиску, фильтрам и сортировке (не только текущая страница). Файл называется «Раздел_ГГГГ-ММ-ДД.xlsx». Текстовые ячейки записываются как текст, поэтому значения вида `=1+1` не выполняются как формулы.

Администрирование (только роль «Администратор»)

- **Пользователи** — список с поиском и фильтрами по роли и статусу, создание, изменение, блокировка, удаление (логическое). Защиты: нельзя заблокировать, удалить или понизить самого себя; нельзя оставить систему без действующего администратора. Пароль: не менее 8 символов, буквы и цифры.
- **Журнал действий** — вход, выход, неудачные попытки входа, создание/изменение/удаление объектов. Фильтры: пользователь, действие, объект, период. По умолчанию сначала самые свежие записи.

Блокировка, смена роли, прав или пароля действуют сразу: при следующем запросе пользователя его сессия завершается (в cookie хранится отпечаток учётной записи, он сверяется с базой). После обновления до этой версии нужно войти заново.

Главная страница

Сводка: число организаций, действующих сотрудников, активных групп (набор и идёт обучение), сколько сотрудников прошли обучение, счётчики срочных («красных») и скорых («жёлтых») уведомлений, пять ближайших повторных обучений и пять ближайших активных групп. Уведомления на главной и на странице «Уведомления» считаются одним и тем же запросом (`RetrainingQuery`).

Демо-данные и проверка быстродействия

Администрирование → «Тестовые данные».

- «Добавить демо-данные» — 5 организаций, сотрудники, 6 программ, группы и записи об обучении с разным сроком до повторного. Кнопка доступна только в пустой системе.
- «Добавить тестовых сотрудников» — 1 000 или 10 000 сотрудников с 1–3 записями об обучении у каждого. Все тестовые записи помечены (`[ТЕСТ]`, почта `@test.local`) и удаляются кнопкой «Удалить тестовые данные». В журнал пишется одна строка вместо тысяч.
- Внизу каждой страницы выводится «Страница сформирована за N мс» — по ней замеряется быстродействие списков, поиска, сортировки, уведомлений и главной при 10 000 сотрудников.

Проверка безопасности (ПК 4.4)

Что заложено в систему и как это проверить руками:

Требование	Как реализовано	Как проверить
Доступ только после входа	`AuthorizeFolder("/")`, анонимно открыта только страница входа	Открыть `/People` в окне без входа → переход на `/Account/Login`
Разделение ролей	Раздел `/Admin` — политика `AdminOnly`	Войти как `metodist`, открыть `/Admin/Users` → «Доступ запрещён»; пункта меню нет
Права методиста на изменение	Политики `CanEditOrganizations`, `CanEditPeople`	Снять права в карточке пользователя → кнопки изменения пропадают, прямой адрес `/Organizations/Edit` даёт отказ
Пароли	Хеш PBKDF2 с солью (`PasswordHasher`), в БД пароля нет	В pgAdmin открыть `AppUsers` → колонка `PasswordHash`
Блокировка действует сразу	Отпечаток учётной записи в cookie сверяется с БД	Заблокировать пользователя, обновить его страницу → переход на вход
SQL-инъекции	Только запросы EF Core, без сырого SQL	Ввести в поиск `' OR 1=1 --` → пустой список, без ошибок
XSS	Razor экранирует вывод, `Html.Raw` не используется	Создать организацию с названием `<script>alert(1)</script>` → отображается текстом
CSRF	Токены защиты форм в каждой POST-форме	Отправить POST без токена → 400
Загрузка файлов	Белый список расширений, лимит размера, имя на диске генерируется системой	Загрузить `.exe` → отказ
Заголовки	`X-Content-Type-Options`, `X-Frame-Options`, `Referrer-Policy`	Вкладка Network в браузере → заголовки ответа
Журнал	Вход, выход, неудачные входы, все изменения	Администрирование → Журнал действий

Тесты

Проект `TrainingRegistry.Tests` (xUnit) проверяет правила повторного обучения, расчёт срочности, договоры, выгрузку в Excel и правила демо-данных. Запуск из корня решения:

```
dotnet test
```

Публикация на GitHub

1. Добавьте в `.gitignore`: `bin/`, `obj/`, `.vs/`, `App_Data/` и `appsettings.json` (там пароль от базы).
2. `git init`, `git add .`, `git commit -m "Первый коммит"`.
3. Создайте пустой репозиторий на GitHub и выполните `git remote add origin <адрес>` и `git push -u origin main`.

Частые проблемы

Симптом	Что делать
Ошибка подключения к базе	Проверьте, что служба PostgreSQL запущена, а логин, пароль и порт в `appsettings.json` верны
Ошибки пакетов при сборке	Выполните `dotnet restore` в папке `TrainingRegistry`
`dotnet ef` не найден	Установите инструмент: `dotnet tool install --global dotnet-ef`

Симптом	Что делать
После обновления не пускает	Выйдите и войдите заново (изменился формат cookie)